

# Security+ 2.4 · Application Attacks

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 2.4** —  
Application Attacks (11:48) · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

---

**Executive Lesson Summary:** Applications are the most attacked surface: privilege escalation (horizontal = same level, different data; vertical = higher tier — user becomes admin); directory traversal (../../etc/passwd); remote code execution. Defenses: input validation, patching, WAF, SCA (vulnerable libraries), secure coding.

## High-Yield Core Concepts Tested on Exam

---

- Privesc horizontal (same level, different data) vs vertical (higher tier)
- Directory traversal: climbs with ../ to /etc/passwd
- Defense: input validation ALWAYS; never trust input
- Remote code execution is a critical application attack
- SCA identifies vulnerable third-party libraries

## Exam Tips & Classic Scenarios

---

- 'user gains higher-level access' = privilege escalation (vertical)
- 'path traversal reads arbitrary files' = directory traversal

**Typical Exam Scenario:** Scenario: 'a regular user accesses another user's account' = horizontal privesc; 'user becomes admin' = vertical.

## **Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 2.4 — Application Attacks)**

---

**Why is this advanced coverage required for SY0-701?** Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **Principle of Least Privilege:** Users and computational entities must be granted only the minimum permissions strictly required to perform designated tasks.
- **Defense-in-Depth (Layered Security):** Application of multiple security controls (technical, administrative, physical) to prevent single-point perimeter compromise.

### **Classic CompTIA Traps & Question Framing:**

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

## **Practice Questions with In-Depth Solutions (10 Questions)**

---

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

**1. An attacker enters as a regular user and becomes 'Domain Admin'. This gain of power is:**

- A)** Privilege escalation
- B)** Denial of service
- C)** Social engineering
- D)** Sniffing

**2. SQL command injection in a login field primarily exploits the lack of:**

- A) Disk encryption**
- B) Input validation**
- C) Backup**
- D) Antivirus**

**3. Corporate scenario (Application Attacks):** During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'Horizontal privesc (same level, another data) vs vertical (tier above).' What is the best recommendation or applicable control classification?

- A) Temporarily disable audit logs to accelerate system throughput**
- B) Replace preventive technical controls with informal terms of adherence**
- C) Allow shared access among administrators using generic credentials**
- D) Implement the corresponding solution: Horizontal privesc (same level, another data) vs vertical (tier above)...**

**4. Corporate scenario (Application Attacks):** During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'Directory traversal: goes up with ../ to /etc/passwd'. What is the best recommendation or applicable control classification?

- A) Temporarily disable audit logs to accelerate system throughput**
- B) Replace preventive technical controls with informal terms of adherence**
- C) Implement the corresponding solution: Directory traversal: goes up with ../ to /etc/passwd...**
- D) Allow shared access among administrators using generic credentials**

**5. Corporate scenario (Application Attacks):** During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'Defense: input validation ALWAYS; never trust input'. What is the best recommendation or applicable control classification?

- A) Implement the corresponding solution: Defense: input validation ALWAYS; never trust input**
- B) Temporarily disable audit logs to accelerate system throughput**
- C) Replace preventive technical controls with informal terms of adherence**
- D) Allow shared access among administrators with generic credentials**

**6. Corporate scenario (Application Attacks):** During a security review and compliance audit for the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'user gains higher-level access' = privilege escalation (vertical). What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: 'user gains higher-level access' = privilege escalation (vertical)...
- C)** Replace preventive technical controls with informal adherence terms
- D)** Allow shared access among administrators with generic credentials

**7. Corporate scenario (Application Attacks):** During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'path traversal reads arbitrary files' = directory traversal. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: 'path traversal reads arbitrary files' = directory traversal...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

**8. Corporate scenario (Application Attacks):** During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'Scenario: 'regular user accesses another user's account' = horizontal privesc; 'user becomes admin' = vertical.' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: Scenario: 'regular user accesses another user's account' = horizontal privesc...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

**9. Corporate scenario (Application Attacks):** During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'Horizontal privesc (same level, another data) vs vertical (tier above)'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators with generic credentials
- D)** Implement the corresponding solution: Horizontal privesc (same level, another data) vs vertical (tier above)

**10. Corporate scenario (Application Attacks):** During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'Directory traversal: climb with ../ to /etc/passwd'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: Directory traversal: climb with ../ to /etc/passwd...
- D)** Allow shared access among administrators using generic credentials

## COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

### 1) A — Privilege escalation.

✓ **Why it's correct:** Privilege escalation is the technique in which an attacker, after gaining initial access with a regular user, exploits vulnerabilities, misconfigurations, or poorly protected credentials to elevate their permission level within the system. In the context of CompTIA Security+ (SY0-701), this concept is classified as a post-exploitation tactic (TA0004 in MITRE ATT&CK) and can be vertical (from regular user to administrator) or horizontal (from one user to another with similar privileges). The statement describes exactly the transition from 'regular user' to 'Domain Admin', which is the classic example of vertical privilege escalation in Windows Active Directory environments. Therefore, the correct option is the one that identifies this movement as privilege escalation.

### ✗ **Why the others are wrong:**

- *Denial of service:* Denial of service (DoS) is an attack that aims to make a resource, service, or network unavailable to legitimate users, typically by overwhelming requests, exhausting resources, or exploiting flaws that cause crashes. In the described scenario, the attacker is not trying to take down the service but to gain more power within the domain. DoS does not involve privilege elevation; it affects availability, not the confidentiality or integrity of permissions. Therefore, it does not apply to the gain of power from regular user to Domain Admin.
- *Social engineering:* Social engineering is the psychological manipulation of people to reveal confidential information or perform actions that compromise security, such as clicking malicious links or providing credentials. Although social engineering can be an initial vector to gain access, it does not describe the technical process of privilege elevation within the system. The statement focuses on the gain of power after access, not the initial method of obtaining it. Therefore, social engineering is not the correct classification for the transformation from regular user to Domain Admin.
- *Sniffing:* Sniffing (or eavesdropping) is the passive interception of network traffic to capture sensitive data, such as cleartext credentials or session information. It is an information-gathering technique, not privilege elevation. Even if sniffing could lead to obtaining administrative credentials, it is not the act of escalating privileges itself. The statement describes the end result (becoming Domain Admin), not the method of traffic capture. Therefore, sniffing is not the correct answer to classify the gain of power.

### 2) B — Input validation.

✓ **Why it's correct:** The correct alternative is 'Input validation'. SQL injection (SQLi) occurs when an application concatenates user-supplied data directly into a SQL query without proper sanitization or parameterization. In the context of a login field, the attacker inserts special characters (such as single quotes, SQL comments, logical operators) to manipulate the query logic, for example, transforming 'SELECT \* FROM users WHERE user='admin' AND pass='password'" into an always-true condition ('OR 1=1 --'). The root cause is the absence of input validation, which should ensure that received data conforms to the expected format (e.g., only alphanumeric characters, maximum length) and, more importantly, the use of parameterized queries (prepared statements) that separate SQL code from data. CompTIA Security+ SY0-701, in the Architecture and Design domain (2.3), emphasizes input validation as a fundamental control to prevent injections. Therefore, the main flaw exploited is the lack of input validation.

### ✗ **Why the others are wrong:**

- *Disk encryption:* Disk encryption (e.g., BitLocker, LUKS) protects data at rest, ensuring confidentiality if the physical device is stolen. It has no relation to the logic of a SQL query at

runtime. Even with fully encrypted disk, SQL injection would still work because the attack occurs at the application layer, not at storage. Therefore, it is a data-at-rest protection technology, not an input validation control.

- *Backup*: Backup is a process of copying data for recovery in case of loss, corruption, or disaster. Although essential for business continuity, it does not prevent SQL injection from being executed. A backup can help restore data after a successful attack, but it does not address the root cause of the vulnerability. SQL injection exploits the lack of input validation, not the absence of backup copies.
- *Antivirus*: Antivirus is software that detects and removes known malicious code, such as viruses, worms, and trojans, based on signatures or heuristics. It does not analyze incoming traffic to a web application for malicious SQL commands. SQL injection is an application attack that can be executed without any malware on the server or client. Therefore, antivirus is not an effective control against SQL injection; the correct defense is input validation and parameterized queries.

### **3) D — Implement the corresponding solution: Horizontal privesc (same level, another data) vs vertical (tier above)....**

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Application Attacks): Horizontal privesc (same level, another data) vs vertical (tier above). Horizontal privilege escalation occurs when an attacker gains access to resources of another user with the same privilege level, while vertical privilege escalation involves gaining higher-level privileges.

#### **✗ Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detect incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who made critical changes or malicious commands.

### **4) C — Implement the corresponding solution: Directory traversal: goes up with ../ to /etc/passwd....**

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Application Attacks): Directory traversal: goes up with ../ to /etc/passwd. Directory traversal is an attack that exploits insufficient input validation to access files and directories outside the intended web root, often using ../ sequences to navigate to sensitive system files like /etc/passwd.

#### **✗ Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials*: Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

**5) A — Implement the corresponding solution: Defense: input validation ALWAYS; never trust input.**

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Application Attacks): Defense: input validation ALWAYS; never trust input. Input validation is a critical defense against injection attacks (SQLi, XSS, command injection) by ensuring only properly formatted data is processed.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

**6) B — Implement the corresponding solution: 'user gains higher-level access' = privilege escalation (vertical)....**

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Application Attacks): 'user gains higher-level access' = privilege escalation (vertical).

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal adherence terms:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who made critical changes or malicious commands.

**7) A — Implement the corresponding solution: 'path traversal reads arbitrary files' = directory traversal....**

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Application Attacks): 'path traversal reads arbitrary files' = directory traversal. Path traversal (directory traversal) is an attack that allows an attacker to access files and directories outside the web root by manipulating file path references. The correct control is to implement defenses such as input validation and proper file system permissions.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual

accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

**8) B — Implement the corresponding solution: Scenario: 'regular user accesses another user's account' = horizontal privesc....**

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Application Attacks): Scenario: 'regular user accesses another user's account' = horizontal privesc; 'user becomes admin' = vertical.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who made critical changes or malicious commands.

**9) D — Implement the corresponding solution: Horizontal privesc (same level, another data) vs vertical (tier above).**

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Application Attacks): Horizontal privesc (same level, another data) vs vertical (tier above). This distinction is crucial for understanding privilege escalation attacks.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

**10) C — Implement the corresponding solution: Directory traversal: climb with ../ to /etc/passwd....**

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Application Attacks): Directory traversal: climb with ../ to /etc/passwd.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user behavior, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual

accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.